RAPPORT TP 3.2 — Attaque d’un système Windows et extraction d’identifiants

Objectif du TP

Comprendre comment un attaquant peut compromettre une machine Windows via :

- L'exploitation de services mal configurés (SMB)
- L'utilisation d'identifiants faibles
- L'extraction d'informations sensible

- **Vérification de l'accessibilité de la cible**

```
merdouce@kali: ~
┌──(merdouce㉿kali)-[~]
└─$ ping 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=0.855 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=0.461 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=0.477 ms
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=0.390 ms
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=0.509 ms
64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=0.420 ms
^C
```

- **Identification des services Windows exposés**

```
┌──(merdouce㉿kali)-[~]
└─$ hydra -l student -p /usr/share/wordlists/rockyou.txt  ssh: 192.168.56.10
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-28 14:27:
36
[ERROR] Unknown service: 192.168.56.10
```

- **Récolte d'informations système sans authentification**

```
merdouce@kali: ~

Nmap done: 1 IP address (1 host up) scanned in 9.60 seconds

┌──(merdouce㉿kali)-[~]
└─$ nmap -p 445 --script smb-os-discovery  192.168.56.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 12:59 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00056s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:36:86:06 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Windows 7 Ultimate 7601 Service Pack 1 (Windows 7 Ultimate 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: HP-WORSTATION
|   NetBIOS computer name: HP-WORSTATION\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-04-28T11:59:27-07:00

Nmap done: 1 IP address (1 host up) scanned in 4.35 seconds

┌──(merdouce㉿kali)-[~]
└─$
```

- **Tentative d'accès à un partage**

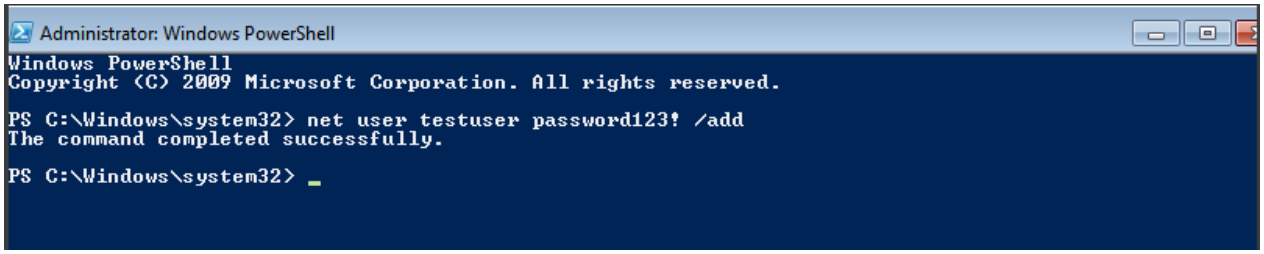
```
┌──(merdouce㉿kali)-[~]
└─$ smbclient -L  //192.168.56.20 -N
Anonymous login successful

        Sharename       Type      Comment
        ---------       ----      -------
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.20 failed (Error NT_STATUS_RESOURCE_NAME_NO
T_FOUND)
Unable to connect with SMB1 -- no workgroup available

┌──(merdouce㉿kali)-[~]
└─$
```

Windows 7 par mesure de sécurité refuse les accès anonymes par défaut. Mais l'on peut quand même observer les fichiers partages si l'on se connecte avec les identifiants d'un utilisateur

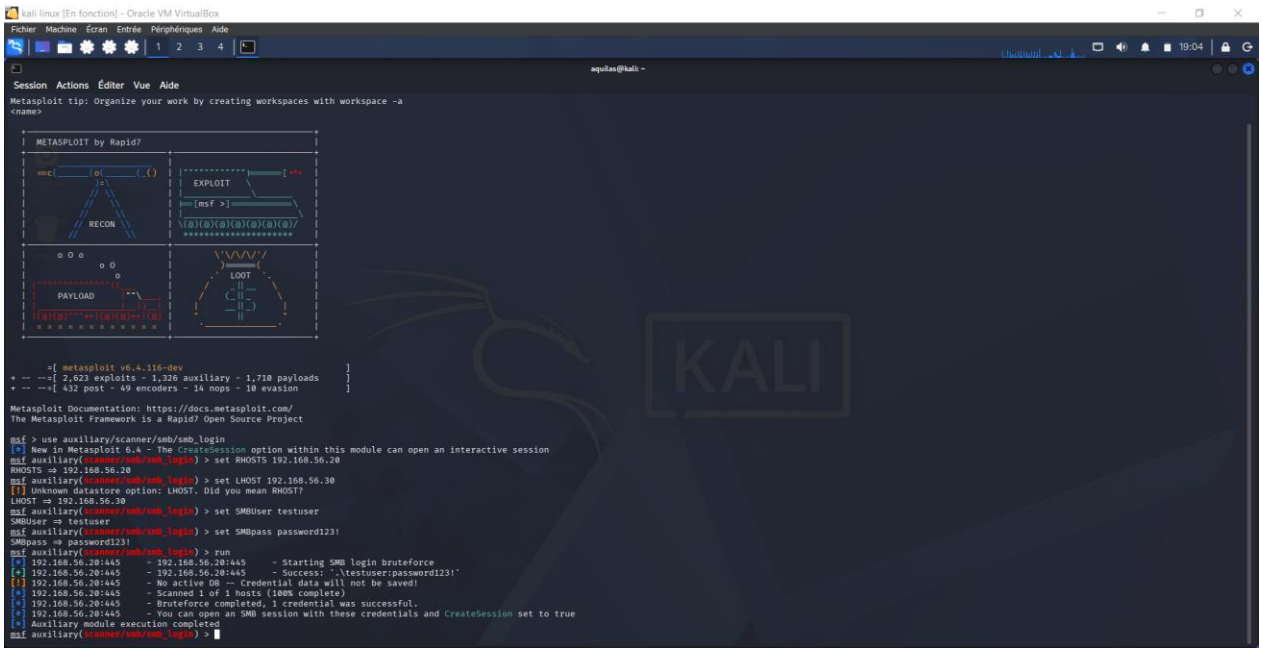
```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) 2009 Microsoft Corporation. All rights reserved.

PS C:\Windows\system32> net user testuser password123! /add
The command completed successfully.

PS C:\Windows\system32>
```

Simulation d'un cas réel — Identifiants faibles

Création d'un compte vulnérable (sur Windows cible)



Test de connexion avec Metasploit



Ouverture d'une session distante sur Windows

Synthèse de l'attaque

1. Découverte → nmap pour identifier SMB
2. Information → smb-os-discovery pour version Windows
3. Accès initial → smbclient partage sans auth
4. Authentification → testuser:Password123!
5. Compromission → psexec + Meterpreter
6. Post-exploitation → hashdump, screenshot, keylogging

Conclusion

Ce travail pratique m'a permis de comprendre :

1. **La compromission ne nécessite pas toujours une vulnérabilité complexe** — Un mot de passe faible ou un partage mal configuré suffisent.
2. **SMB est un vecteur d'attaque critique** — Souvent mal configuré en entreprise.
3. **Post-exploitation = danger réel** — Une fois à l'intérieur, l'attaquant peut extraire identifiants, capturer écrans, enregistrer frappes.